

TestInc Cloud Collaboration Platform

Independent Service Auditor's Report on Controls Relevant to Security, Availability,
Confidentiality, and Privacy
SOC 2 Type II Examination

Service organization	TestInc, Inc.
System	TestInc Cloud Collaboration Platform
Report period	January 1, 2025 through December 31, 2025
Report date	February 16, 2026
Prepared for	Authorized user entities and prospective user entities under NDA

FICTIONAL TEST REPORT: This document is synthetic and was created only for application testing. It is not an actual CPA report, assurance engagement, auditor opinion, certification, or representation about a real company.

Restricted Use

This mock report is modeled after common SOC 2 Type II report structures. Distribution should be limited to testing, training, and demonstration activities. Names, dates, controls, evidence, exceptions, and audit procedures are invented.

Section I - Independent Service Auditor's Report

To the Management of TestInc, Inc.:

Scope

We have examined TestInc, Inc.'s description of its TestInc Cloud Collaboration Platform throughout the period January 1, 2025 to December 31, 2025, and the suitability of the design and operating effectiveness of controls stated in the description to provide reasonable assurance that TestInc's service commitments and system requirements were achieved based on the applicable trust services criteria for security, availability, confidentiality, and privacy.

The system enables higher education, healthcare, and enterprise customers to manage secure document collaboration, workflow approvals, file retention, and API-based integrations. The system stores customer files, user metadata, audit logs, support tickets, and configuration data.

Service Auditor's Opinion

In our opinion, except for the matter described in the Basis for Qualified Opinion paragraph, in all material respects, based on the applicable trust services criteria, the controls stated in TestInc's description were suitably designed and operated effectively throughout the period January 1, 2025 to December 31, 2025 to provide reasonable assurance that TestInc's service commitments and system requirements were achieved.

Basis for Qualified Opinion

During the examination period, management identified that quarterly user access reviews for the production support role were not completed within the required 30-day review window for one quarter. The delayed review affected 14 production support users. Management completed a compensating review on August 18, 2025 and removed one dormant account. No unauthorized activity was identified in the related audit logs.

Inherent Limitations

Because of their nature and inherent limitations, controls at a service organization may not prevent, detect, or correct all errors, omissions, or security events. Also, the projection to future periods of any evaluation of the fairness of the presentation of the description, or conclusions about the suitability of the design or operating effectiveness of controls, is subject to the risk that controls may become inadequate because of changes in conditions or because the degree of compliance with policies or procedures may deteriorate.

Restriction on Use

This fictional report is intended solely for TestInc application testing and training. In a real SOC 2 report, use would generally be restricted to management of the service organization, user entities, prospective user entities, and their auditors or practitioners with sufficient understanding of the system.

Mock & Vale Assurance LLP

Minneapolis, Minnesota
February 16, 2026

Section II - TestInc Management Assertion

Management of TestInc, Inc. is responsible for preparing the accompanying description of the TestInc Cloud Collaboration Platform and for the design, implementation, operation, and monitoring of controls related to the system.

Management asserts that, throughout the period January 1, 2025 to December 31, 2025:

- The description fairly presents the system that was designed and implemented.
- The controls stated in the description were suitably designed to provide reasonable assurance that TestInc's service commitments and system requirements were achieved.
- The controls operated effectively to provide reasonable assurance that TestInc's service commitments and system requirements were achieved, except for the delayed production support access review described in the independent service auditor's report.
- Subservice organizations were monitored using the carve-out method as described in Section III.

Trust Services Categories in Scope

Category	In scope?	Summary
Security	Yes	Logical access, change management, vulnerability management, incident response, monitoring, and risk assessment.
Availability	Yes	Backups, disaster recovery, capacity planning, monitoring, and service continuity.
Confidentiality	Yes	Encryption, retention, deletion, access controls, and confidential customer data handling.
Privacy	Yes	Collection, use, retention, disclosure, and deletion of personal information.
Processing Integrity	No	Processing integrity was not included in this examination.

Signed on behalf of management by Jordan Lee, Chief Security Officer, TestInc, Inc.

Section III - Description of the TestInc System

Company Overview

TestInc, Inc. is a fictional software-as-a-service provider headquartered in Minneapolis, Minnesota. The TestInc Cloud Collaboration Platform allows customers to upload documents, route approvals, manage retention schedules, share content with internal and external collaborators, and review audit events.

Principal Service Commitments

- Protect customer information against unauthorized access and disclosure.
- Maintain availability commitments for production services and customer support.
- Encrypt customer content in transit and at rest using industry-standard cryptography.
- Notify customers of confirmed security incidents without unreasonable delay and within 72 hours when contractually required.
- Support customer responsibilities for retention, deletion, access administration, and single sign-on configuration.

Infrastructure and Subservice Organizations

TestInc uses the carve-out method for subservice organizations. Controls at these organizations are not included in the scope of this mock examination, although TestInc monitors those organizations through annual SOC report review, security questionnaire review, and vendor risk assessment.

Subservice organization	Services provided	Method	Risk note
NorthLake Cloud Services	Cloud hosting, storage, network security groups, managed database platform	Carve-out	Critical hosting dependency; customers should obtain or review the provider's SOC report when required.
RelayDesk Support Systems	Customer support ticketing and knowledge base	Carve-out	May process names, email addresses, institution names, and support attachments.
PayBridge Processing	Invoice payment portal for optional paid plans	Carve-out	PCI responsibilities are primarily handled by PayBridge; TestInc does not store full card numbers.

Data Classification and Customer Data

Depending on customer configuration, the platform may store personally identifiable information, education records, research documents, contract materials, and workflow metadata. TestInc contract templates include optional terms for FERPA, HIPAA/PHI workflows, GLBA customer information, payment card data, and institutional research data. TestInc does not intentionally process controlled unclassified information unless enabled under a separate written agreement.

Access and Authentication

Customers may enable SAML single sign-on, multi-factor authentication, SCIM user provisioning, and role-based access control. TestInc support personnel access production through privileged access workflows requiring MFA, approved tickets, just-in-time elevation, and centralized logging.

Encryption and Key Management

TestInc encrypts data in transit using TLS 1.2 or higher and encrypts customer content at rest using AES-256. Encryption keys are stored in a managed key service with annual access review and key rotation monitoring.

Incident Response and Breach Notification

TestInc maintains an incident response plan, performs annual tabletop exercises, and monitors security alerts through a centralized logging and SIEM platform. Contract templates include breach notification language of 72 hours for confirmed incidents involving regulated customer data where legally or contractually required.

MOCK - TEST DATA

Section IV - Complementary User Entity Controls

The achievement of TestInc's service commitments depends in part on controls performed by user entities. The following complementary user entity controls should be evaluated by customers such as universities, healthcare entities, and enterprise organizations.

CUEC	Expected user entity responsibility	UMN vendor risk relevance
CUEC-1	Configure SSO and MFA for institutional users where supported.	Assign owner for SSO/MFA configuration and exception approval.
CUEC-2	Approve user access based on job responsibilities and remove access promptly when users transfer or terminate.	Map to IAM/offboarding process and vendor owner responsibility.
CUEC-3	Classify data uploaded to the platform and avoid uploading regulated data unless contract terms permit it.	Confirm FERPA, PHI, PCI, GLBA, and research data applicability.
CUEC-4	Review administrative activity logs made available in the tenant console.	Determine whether the business owner or security team monitors tenant activity.
CUEC-5	Configure retention and deletion policies in accordance with institutional records requirements.	Validate retention, legal hold, e-discovery, and deletion requirements.
CUEC-6	Review subservice organization dependencies where the customer's risk profile requires additional assurance.	Request cloud provider or support platform SOC reports for high-risk deployments.

Section V - Tests of Controls and Results

The following abbreviated testing matrix is fictional and designed to exercise SOC 2 review tools. It includes clean results, exceptions, subservice dependencies, and regulated-data signals.

Control ID	Control activity	Testing performed	Result
CC6.1	Logical access to production is restricted based on job responsibilities.	Inspected user listing, privileged access tickets, and role assignments for a sample of 35 users.	No exceptions noted.
CC6.2	Production support access reviews are completed quarterly within 30 days after quarter-end.	Inspected quarterly access review evidence for Q1 through Q4 2025.	Exception noted: Q2 review completed 49 days after quarter-end; one dormant support account removed.
CC6.3	MFA is enforced for production administration and remote access.	Inspected identity provider configuration and sampled 20 privileged users.	No exceptions noted.
CC7.2	Security events are monitored and escalated through the incident response process.	Inspected alerting configuration, SIEM tickets, and incident log for a sample of 12 alerts.	No exceptions noted.
CC8.1	Changes to production are approved, tested, and linked to deployment records.	Selected 25 production changes and inspected approval, testing, and deployment evidence.	One deviation noted: emergency change lacked pre-deployment approval but received post-implementation review.
A1.2	Backups are performed daily and restoration tests are conducted at least annually.	Inspected backup monitoring logs and the October 2025 restoration test summary.	No exceptions noted.
C1.1	Customer confidential information is encrypted at rest and in transit.	Inspected encryption configuration, TLS settings, and key management access.	No exceptions noted.
P4.1	Personal information is retained and deleted according to customer configuration and contractual requirements.	Inspected retention configurations and deletion ticket evidence for a sample of 18 requests.	No exceptions noted.

Section VI - Vendor Risk Analyst Notes

This page is not normally part of a formal SOC 2 report. It is included in this mock report so the UMN-focused application has realistic cues to detect and summarize.

Topic	Risk signal	Suggested follow-up
Qualified opinion	Delayed access review and one dormant account in production support role.	Request remediation evidence, current access review, and confirmation no UMN tenant was impacted.
CUECs	SSO/MFA, access removal, retention, activity log review, and data classification are customer responsibilities.	Assign UMN owners before approval.
Subservice organizations	Cloud hosting, support ticketing, and payment services are carved out.	Request subservice SOC reports if vendor will handle restricted or mission-critical data.
FERPA	Education records may be stored if customers upload student records or academic workflow documents.	Confirm contract language, DPA, data retention, and breach notification obligations.
PHI	PHI workflows require a separate business associate agreement.	Confirm whether the vendor will receive PHI and whether a BAA is in place.
GLBA/PCI	Financial aid, student finance, or payment workflows may require additional safeguards.	Confirm scope, payment processor responsibilities, and data minimization.
Availability	Platform advertises 99.9 percent uptime; backups and annual restore testing are in scope.	Review RTO/RPO against business criticality.

Overall mock risk disposition: Conditional approval recommended pending remediation evidence for the Q2 access review exception, mapping of CUECs to customer owners, and confirmation of applicable regulated data terms.

Appendix A - Criteria Mapping

Criteria	Area	Representative controls in this mock report
CC1.x	Control Environment	Security governance, policy acknowledgement, annual risk assessment, ethics hotline.
CC2.x	Communication and Information	Customer trust center, status page, security notices, support procedures.
CC3.x	Risk Assessment	Annual enterprise risk assessment, vendor risk reviews, threat modeling.
CC4.x	Monitoring Activities	Internal control monitoring, exception tracking, monthly security metrics.
CC5.x	Control Activities	Policy enforcement, approvals, evidence retention, management review.
CC6.x	Logical and Physical Access	SSO, MFA, access reviews, privileged access, physical datacenter reliance.
CC7.x	System Operations	Logging, SIEM monitoring, incident response, vulnerability management.
CC8.x	Change Management	Change approval, testing, deployment controls, emergency changes.
CC9.x	Risk Mitigation	Vendor management, business continuity, security awareness.
A1.x	Availability	Backups, disaster recovery, capacity monitoring, uptime alerts.
C1.x	Confidentiality	Encryption, retention, confidentiality agreements, secure deletion.
P1.x-P8.x	Privacy	Notice, consent where applicable, collection, use, retention, disclosure, and disposal.

Appendix B - Glossary and Disclaimers

Glossary

- CUEC: Complementary User Entity Control, a control the customer is expected to perform.
- Carve-out method: A reporting method where controls at subservice organizations are excluded from the service auditor's testing.
- Type II report: A report covering design and operating effectiveness of controls over a period of time.
- Qualified opinion: An auditor opinion modified because one or more matters are material to the report.
- FERPA: Family Educational Rights and Privacy Act, relevant to education records.
- PHI: Protected health information, generally associated with HIPAA-covered workflows.

Synthetic Document Disclaimer

This PDF is a synthetic, hyperrealistic test artifact for software development. TestInc, Mock & Vale Assurance LLP, NorthLake Cloud Services, RelayDesk Support Systems, and PayBridge Processing are fictional names used for testing. This report should not be used for vendor assurance, audit reliance, procurement, security certification, or compliance decisions.

MOCK - TEST DATA